ANALISI THREAT INTELLIGENCE E PANORAMA DELLE MINACCE *Report Tecnico: Metodologie di Rating e Analisi del Rischio*

---

1. IL SISTEMA DI VALUTAZIONE THREATCONNECT

Il sistema di valutazione di ThreatConnect è fondamentale per la prioritizzazione degli indicatori di compromissione (IoC). Esso si basa su due pilastri principali che consentono agli analisti di distinguere tra rumore di fondo e minacce critiche.

1.1 Threat Rating (Livello di Minaccia)

Rappresenta la potenziale gravità o "malignità" di un indicatore. Viene espresso in una scala da 0 a 5.

- **Livello 0 (Unknown):** Nessun dato disponibile per classificare l'indicatore.
- **Livello 1 (Suspicious):** Comportamenti anomali osservati, ma non necessariamente malevoli.

- **Livello 2 (Low):** Minacce comuni e poco sofisticate, come adware o spam massivo.
- **Livello 3 (Moderate):** Attori con risorse medie; attacchi diretti ma non persistenti.
- **Livello 4 (High):** Minacce altamente pericolose e mirate; fasi di esfiltrazione dati o C2.
- **Livello 5 (Critical):** Minacce APT (Advanced Persistent Threat) con capacità tecniche avanzate.

1.2 Confidence Rating (Livello di Confidenza)
Indica il grado di affidabilità dell'informazione su una scala da 0 a 100. Un rating alto indica che la minaccia è stata confermata da fonti attendibili.

- **0 (Unknown):** Dato non verificato o fonte ignota.
- **1 (Discredited):** Accertato come falso positivo o informazione errata.
- **2 - 49 (Improbable/Doubtful):** Informazione non confermata e spesso illogica.
- **50 - 69 (Possible):** Segnalazione plausibile ma in attesa di ulteriori riscontri.

- **70 - 89 (Probable):** Altamente plausibile e coerente con lo scenario attuale.
- **90 - 100 (Confirmed):** Certezza analitica supportata da prove forensi e multiple fonti.

---

2. ANALISI DELLE MINACCE COMUNI (RAPPORTO CLUSIT) Sulla base delle analisi del Rapporto Clusit, si identificano le seguenti minacce come le più impattanti per il tessuto aziendale moderno.

2.1 Malware e Ransomware

- **Meccanismo:** Cifratura dei dati e "double extortion" (ricatto sulla pubblicazione dei dati rubati). È la minaccia più redditizia per il cybercrime oggi.
- **Danno:** Fermo operativo prolungato, elevati costi di bonifica e danni reputazionali critici.

2.2 Phishing e Social Engineering

- **Meccanismo:** Manipolazione psicologica degli utenti per ottenere credenziali (Spear Phishing) o deviare pagamenti (Business Email Compromise - BEC).

- **Danno:** Punto di ingresso principale nella rete aziendale e frodi finanziarie dirette.

2.3 Attacchi DDoS (Distributed Denial of Service)

- **Meccanismo:** Saturazione delle risorse di rete tramite botnet per rendere indisponibili i servizi esterni (siti web, portali clienti).
- **Danno:** Perdita immediata di fatturato (per gli e-commerce) e possibile diversivo per altre intrusioni silenti.

2.4 Insider Threat (Minaccia Interna)

- **Meccanismo:** Azioni dolose o accidentali da parte di dipendenti o collaboratori con privilegi di accesso.
- **Danno:** Esfiltrazione di segreti industriali e violazione della privacy (GDPR).

---

3. CONCLUSIONI E SINTESI STRATEGICA

L'integrazione del rating ThreatConnect con l'analisi delle minacce reali permette una difesa proattiva. Un attacco Ransomware identificato avrà tipicamente un **Threat Rating 5**, ma l'azione

di difesa (blocco immediato rispetto a semplice monitoraggio) dipenderà dalla **Confidence** assegnata all'alert dagli strumenti di monitoraggio.

Pratica extra:

REPORT ANALISI VULNERABILITÀ E SCENARI DI ATTACCO

Mappatura Standard: OWASP Top 10 e MITRE ATT&CK Enterprise

INTRODUZIONE

Il presente documento analizza tre scenari critici di sicurezza informatica, fornendo la classificazione secondo gli standard internazionali OWASP (Open Web Application Security Project) e le tecniche descritte nel framework MITRE ATT&CK.

ANALISI DEGLI SCENARI

1. Scenario: Cross-Site Scripting (XSS)

- **Descrizione:** Esecuzione di script dannosi nel browser dell'utente tramite form online non validati per il furto di sessione.
- **OWASP Top 10:** A03:2021 – Injection.
- **MITRE ATT&CK:** T1553.005 (User Execution) / T1539 (Steal Web Session Cookie).
- **Mitigazione Suggerita:**
  - **M1050 (Exploit Protection):** Implementare il Context-aware output encoding.
  - **Configurazione Cookie:** Utilizzo degli attributi HttpOnly e Secure.
  - **Content Security Policy (CSP):** Configurare una policy per bloccare script non autorizzati.

2. Scenario: SQL Injection (SQLi)

- **Descrizione:** Manipolazione dell'interfaccia di login per eseguire comandi SQL non autorizzati ed estrarre dati sensibili dal database.
- **OWASP Top 10:** A03:2021 – Injection.

- **MITRE ATT&CK:** T1190 (Exploit Public-Facing Application).
- **Mitigazione Suggerita:**
  - **M1050 (Exploit Protection):** Utilizzo tassativo di Prepared Statements (query parametrizzate).
  - **M1026 (Privileged Account Management):** Applicare il principio del minimo privilegio all'utente del database.

3. Scenario: Deserializzazione Non Sicura

- **Descrizione:** Esecuzione di codice arbitrario sul server (RCE) tramite la manipolazione di oggetti serializzati inviati dall'utente.
- **OWASP Top 10:** A08:2021 – Software and Data Integrity Failures.
- **MITRE ATT&CK:** T1203 (Exploitation for Client Execution) / T1059 (Command and Scripting Interpreter).
- **Mitigazione Suggerita:**
  - **M1050 (Exploit Protection):** Validazione rigorosa o rifiuto di oggetti serializzati da

fonti esterne (preferire formati puri come JSON).

- **Controlli di Integrità:** Implementazione di firme digitali (HMAC) sugli oggetti per prevenire manomissioni.

TABELLA DI SINTESI

Scenario	Vulnerabilità OWASP	Tecnica MITRE	Impatto Principale
Attacco XSS	A03:2021 Injection	T1553.005	Furto di Sessione
SQL Injection	A03:2021 Injection	T1190	Esfiltrazione Dati
Deserializzazione	A08:2021 Integrity	T1059	Esecuzione di Codice (RCE)